MERROWFIELD DIGITAL

Playbook: Phishing and credential compromise

Document Playbook 01 | Rev 3 | Effective 9 February 2026 | Owner: Security Operations | Review cycle: 12 months

1. What this playbook covers

This playbook covers credentials harvested by a phishing email or a lookalike login page, accounts taken over with them, consent granted to a malicious application, and mailbox rules created by an intruder. It is used by the Security Analyst who investigates, from the first alert until the incident is closed.

2. How it is usually recognised

- a user reporting an email that asked them to sign in or confirm details
- an impossible-travel alert, or a sign-in from a hosting provider
- a user reporting a multi-factor prompt they did not start
- a new mailbox rule forwarding mail outside the company
- a third party reporting seller or customer accounts being taken over

3. The first hour

1. Revoke every session of the affected accounts and force a password reset.
2. Enforce multi-factor authentication for the account group if it was not already enforced.
3. Block the lookalike domain at the mail gateway and the web proxy, and purge the lure from every mailbox it reached.
4. Remove malicious mailbox rules and revoke consent granted to unknown applications.
5. Find out whether the same password gave access anywhere else, and rotate it there too.

4. Evidence to preserve

- the original email with its full headers, and the list of recipients
- sign-in logs for the affected accounts
- mailbox audit logs and application consent records
- proxy and DNS logs for the lookalike domain

5. Establishing the facts a report needs

Whatever is decided, the decision needs these facts, established as early as they can be:

- which accounts were compromised, and what data each could reach
- whether data was exported or viewed - whether exfiltration is confirmed
- whether credentials were exposed in plaintext or as salted hashes
- how many customers are affected, in the EU and in India
- whether other incidents came from the same kit, and share a campaign reference

6. Reporting

Which reporting procedures apply is settled from the incident's facts by the rules in Plan 01, section 8, and each procedure's deadlines are read from that procedure. This playbook sets no deadline of its own, and the decision belongs to the Data Protection Officer.

Incidents from one phishing kit share a campaign reference. For Procedure 02 their customers are added together, so an incident can be significant only because of its campaign.

7. What affected customers should do

When customers are told, the notice gives them these steps, in this order:

- Change your Merrowfield password now, and change it anywhere else you used the same password.
- Turn on two-step verification in your account settings.
- Merrowfield never asks for your password by email, text message, phone or chat. Do not enter it on a page you reached from a link in a message.

- Check your recent orders, saved addresses and payment methods, and tell us about anything you do not recognise.
- Be careful with emails that mention this incident and ask you to click a link or open an attachment; go to the app or website directly instead.

8. Closing the incident

Run a targeted awareness exercise for the team that was phished, request takedown of the lookalike domain, and record what would have caught the lure sooner.